MID-STATE TECHNICAL COLLEGE · IT PROGRAMS

Lateral Movement

Unit 12 · Ethical Hacking (10-151-160)

MID-STATE TECHNICAL COLLEGE

Learning Outcomes

By the end of this unit, you will be able to:



Harvest credentials

Collect passwords, hashes, and tickets from hosts and from the network.



Discover & map the environment

Enumerate hosts, accounts, shares, and trusts from a foothold.



Move laterally

Reuse credentials and pivot to reach higher-value systems.



Detect & mitigate movement

Recognize and contain an attacker with Blue Team controls.

LESSON 1

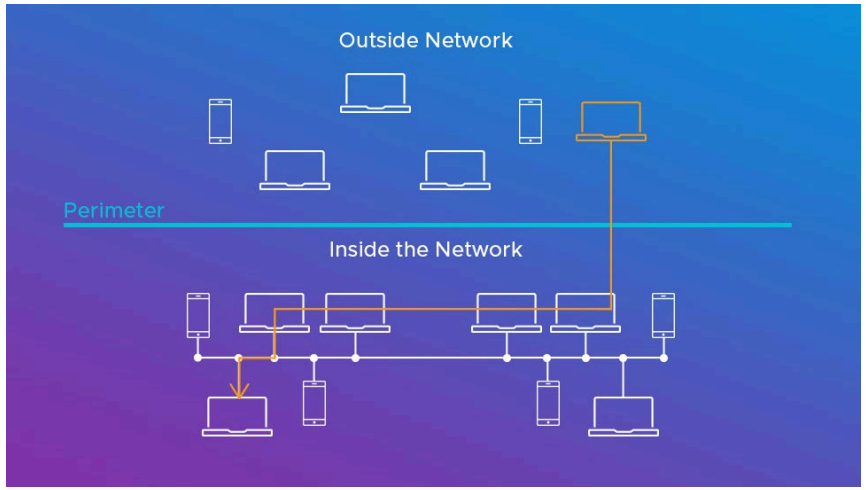
Lateral Movement Fundamentals



What Is Lateral Movement?

Everything an attacker does after the first compromise and before reaching the final objective.

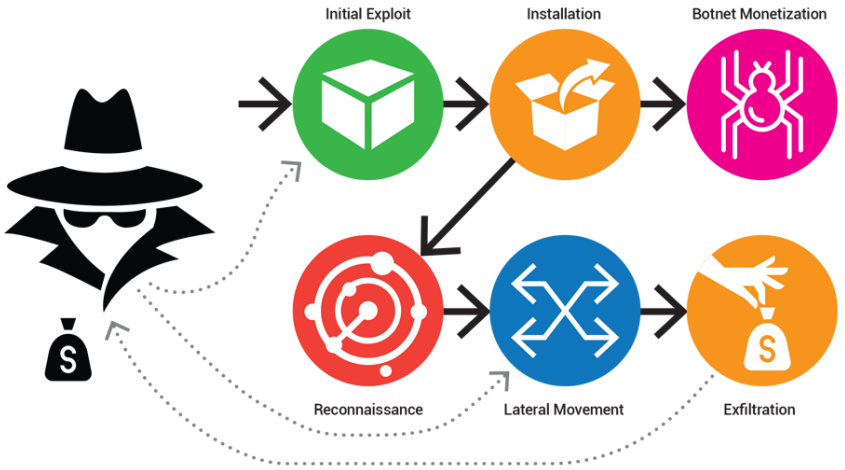
- It turns a **single foothold** into access across the environment.
- It is **iterative** — attackers loop through discovery, credential access, and movement.
- The goal is reach: **data**, **domain controllers**, and other high-value systems.



Where It Sits in the Attack Lifecycle

A distinct stage in every attack framework — not a one-time event.

- On the **Cyber Kill Chain**, it follows initial access, execution, and privilege escalation.
- In **MITRE ATT&CK**, Lateral Movement is its own tactic (`TA0008`).
- It interleaves with **Discovery** and **Credential Access** on every hop.



Why Attackers Move Laterally

- **Reconnaissance** — deploy remote-access tooling and learn the network from the inside.
- **Credentials & privileges** — gather logins that reach accounts the first host could not.
- **Gaining access** — infiltrate and move toward the data or systems that are the real objective.



The loop

Discover → harvest credentials → move → discover again. Attackers repeat the cycle until they reach the goal.

LESSON 2

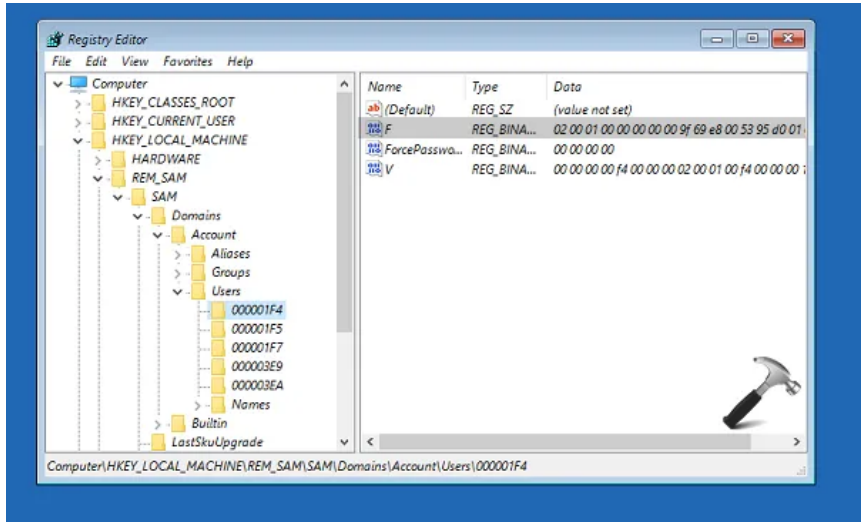
Harvesting Credentials



Where Credentials Live

Before you can reuse a credential, you have to collect it:

- **Windows SAM** — local hashes at `C:\Windows\System32\config\SAM` (hive `HKLM\SAM`).
- **Domain controller** — domain hashes in the AD database (`NTDS.dit`).
- **In memory** — `LSASS` holds hashes and tickets while users are logged in.
- **On the wire** — hashes and challenge-responses can be captured in transit.



Mimikatz & Mimipenguin

The classic tools for pulling credentials straight out of memory.

- **Mimikatz** (Windows) — dumps plaintext, hashes, and Kerberos tickets from `LSASS`.
- **Mimipenguin** (Linux) — pulls credentials from memory on Linux hosts.



Credential Guard: On Windows 10 Enterprise and later, virtualization-based security isolates LSASS secrets and makes pass-the-hash much harder.

Responder — Capturing Hashes on the Wire

When a credential is not on the box, take it off the network.

- Poisons **LLMNR/NBT-NS** name resolution to become a man-in-the-middle.
- Answers broadcast lookups and **captures the authentication** hash.
- Captured hashes are then **cracked offline** or **replayed** in a pass-the-hash attack.

SpiderLabs/
Responder

Responder is a LLMNR, NBT-NS and MDNS poisoner, with built-in HTTP/SMB/MSSQL/FTP/LDAP rogue authentication server supporting NTLMv1/NTLMv2/LMv2, Extended Security NTLMSSP and...

LESSON 3

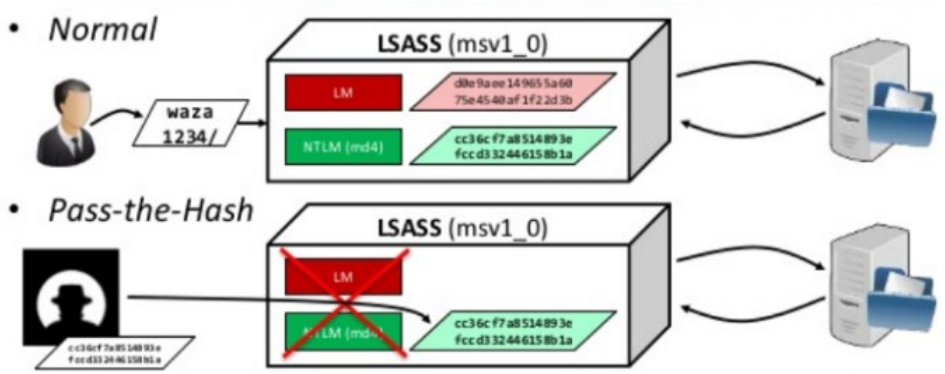
Credential & Token Reuse



Pass the Hash

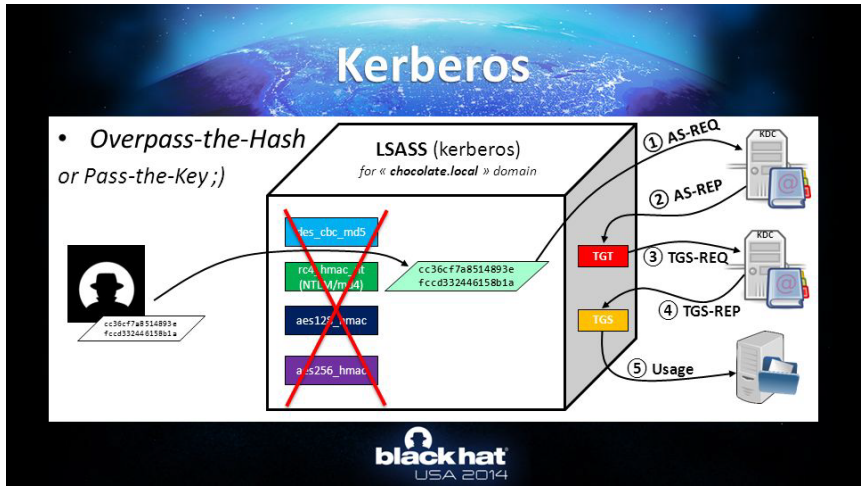
Reuse the hash directly — never crack the password at all.

- Windows stores passwords in memory as **NTLM hashes**.
- The hash can be **replayed** to authenticate to other systems.
- No plaintext needed — the hash **is** the credential.



Kerberos Ticket Reuse

- **Pass the Ticket** — reuse a Kerberos ticket issued to a trusted client to reach any service that trusts it.
- **Over-Pass-the-Hash (Pass the Key)** — use a stolen hash or key to request a fresh Kerberos ticket.
- Both let an attacker authenticate **without the password**.



Golden & Silver Tickets

Golden Ticket

- A forged Kerberos **TGT** signed with the domain `KRBTGT` hash.
- Grants near-unlimited, long-lived domain access.
- The crown-jewel compromise — protect KRBTGT.

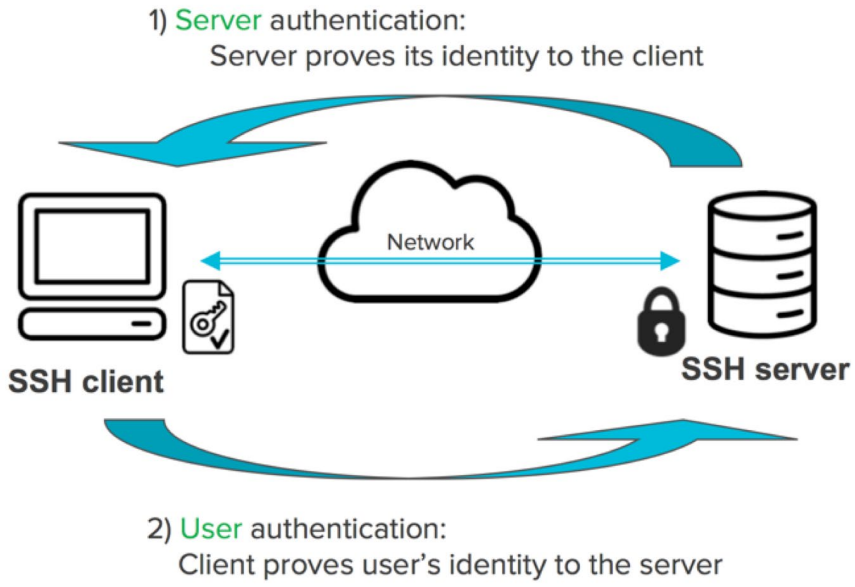
Silver Ticket

- A forged **service ticket** for a single service.
- Quieter — it never contacts the domain controller.
- Narrower scope, harder to spot.

Both forge Kerberos authenticators rather than stealing them — detection shifts from "who logged in" to "which tickets are valid."

Reusing Keys & Cached Tickets

- **Pass the Cache** — find a cached Kerberos ticket on a Linux host and reuse it across the domain.
- **SSH key reuse** — a reused private key may be the only proof of identity needed to reach many hosts.
- Keys and tickets are **credentials too** — and are often left unprotected.



LESSON 4

Guessing, Interception & Discovery

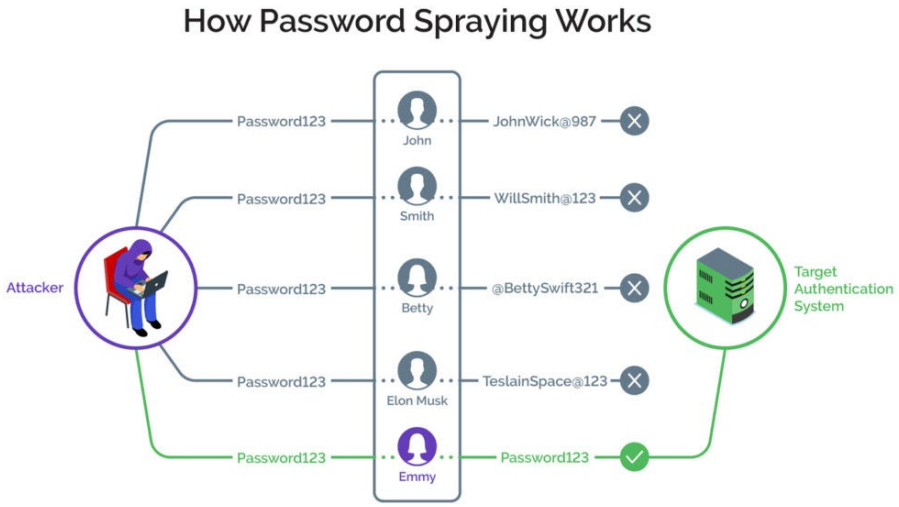


Ethical Hacking · Lateral Movement

Password & Authentication Attacks

When you cannot steal a credential, guess it — carefully.

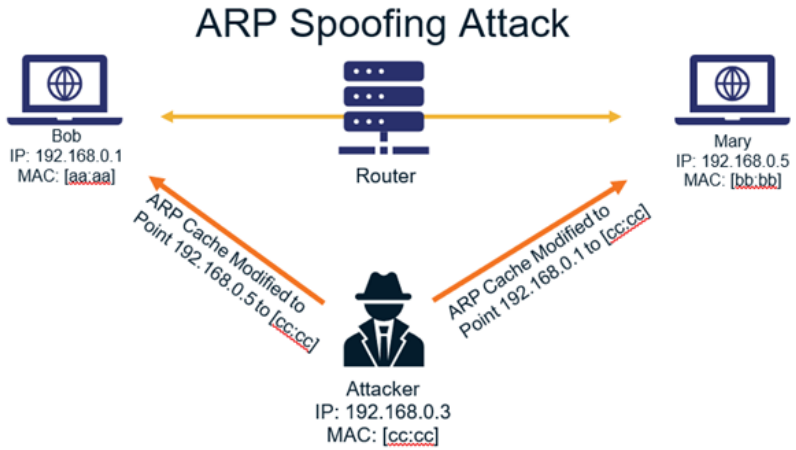
- **Wordlists** — start from `RockYou`, then add custom words from recon.
- **CeWL** — spiders a target site to build a tailored wordlist.
- **John the Ripper** — cracks captured hashes offline.
- **Password spraying** — one common password across many accounts, under the lockout threshold.



Network-Based Interception

Some credentials are easiest to take by getting in the middle.

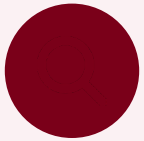
- **ARP poisoning** — forge ARP replies to become the **man-in-the-middle** on a segment.
- **Side jacking** — steal session cookies to ride an authenticated session.
- **DNS redirection** — send a victim to a spoofed intranet page to capture a login.
- **SSL strip** — downgrade HTTPS to HTTP to expose credentials in cleartext.



Discovering the Target Environment

Map the network from the inside — discovery turns a foothold into a plan.

- **Hosts & services** — live systems, open ports, and the roles they play.
- **Accounts & groups** — local and domain users, privileged groups, who is logged in where.
- **Shares & data** — readable shares that leak credentials and scripts.
- **Trust relationships** — domain trusts and service accounts that open paths.



MITRE Discovery (TA0007)

The same enumeration a defender does to **know their network** is what an attacker does to find a route through it.

Pivoting & Tunneling

Reach a segmented system by routing your traffic through a host you already own.

- **Port forwarding** — `portfwd` relays a port on the foothold to an internal service.
- **Routing & proxied pivots** — add a route through a session to attack an internal subnet.
- **dnscat2** — tunnel command-and-control over DNS when other egress is blocked.
- **Automation** — resource scripts make pivots repeatable and auditable.



LESSON 5

Detection & Mitigation



Ethical Hacking · Lateral Movement

Limit the Blast Radius

Shrink what a stolen credential can reach before an attacker ever arrives.

- **Least privilege** — users and services get only the access they need.
- **Allow lists** — constrain which applications run, which users reach which systems, and which external connections are permitted.
- Together they **shrink the blast radius** of any one compromise.



Detection: EDR & Monitoring

Catch the movement prevention missed by watching behavior.

- **EDR** — Endpoint Detection and Response flags credential-dumping and remote-execution behavior.
- **Wazuh** — a capable open-source EDR/XDR option.
- **Know your network** — baseline normal authentication so anomalous lateral logons stand out.

Open-source option

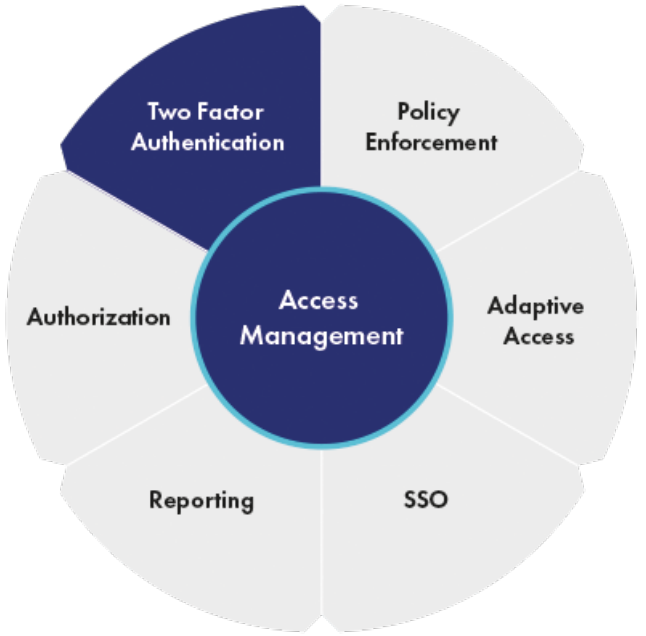
Wazuh pairs host telemetry with detection rules you can tune to this unit's techniques.



Authentication Management

Make stolen credentials insufficient on their own.

- **Password management** — length, uniqueness, and rotation reduce crackable material.
- **Multi-factor authentication** — a stolen hash or password alone is not enough.
- **Ticket protection** — safeguard and rotate the `KRBTGT` account to limit forged tickets.



When You Can’t Remediate

Some exposures can’t be closed before the engagement ends — document them as controls.

SECURITY FOCUS

A legacy app that needs a shared local admin, or a flat segment that can’t be re-architected in time, becomes a **control requirement**: state the risk, why it can’t be fixed now, and the compensating controls — enhanced monitoring, tighter allow lists, credential rotation — until it can.

Why it matters: An unremediated exposure left undocumented is a finding the organization never gets to act on.

The Attacker's Toolkit

Know what each tool is for, not just its name:

Tool	Platform	Purpose
Mimikatz	Windows	Dump plaintext, hashes, and Kerberos tickets from memory
Mimipenguin	Linux	Dump credentials from memory
Responder	Network	Capture hashes by poisoning LLMNR/NBT-NS
Metasploit / Meterpreter	Both	Pivoting, port forwarding, session management
John the Ripper	Both	Crack captured hashes offline
CeWL	Both	Build custom wordlists from a target site
dnscat2	Both	Tunnel command-and-control over DNS

Detecting Lateral Movement

Movement hides inside valid logins — so look for the anomaly, not a signature.

SECURITY FOCUS

Watch for **authentication from unexpected sources**, **remote-execution artifacts** (service installs, scheduled tasks, WMI), and **one account authenticating across many hosts** in a short window. Correlate across endpoints — any single event looks normal.

Why it matters: The gap between "logged in" and "logged in from somewhere it shouldn't be" is where lateral movement is caught.

Hands-On Lab: Harvest, Reuse, Move

Your Kali + Windows lab VMs, or an equivalent room on Hack The Box or TryHackMe:



- Harvest a credential — hash, ticket, or password — from a compromised host.
- Reuse it to authenticate to a second system and confirm access.
- Record the full path, with screenshots, and note which control would stop each step.
- Treat captured data as **TLP:AMBER** and keep it inside the lab.

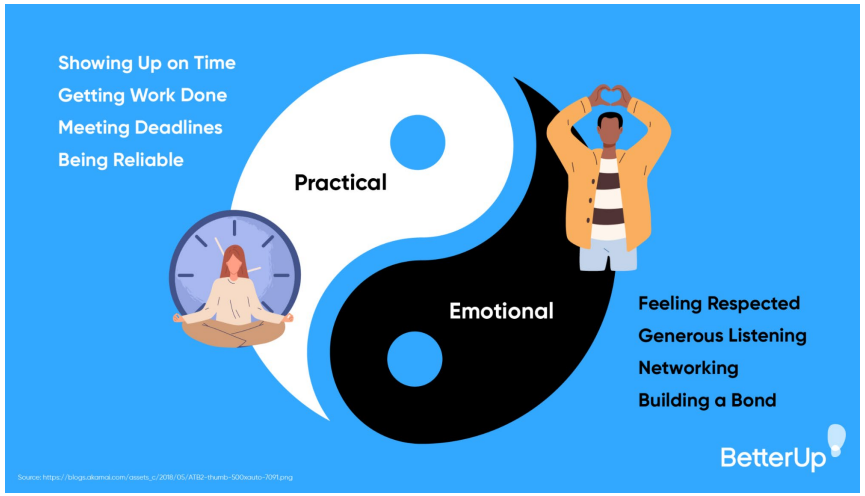
Key Takeaways

- Lateral movement turns one foothold into access across the network.
- Credentials are harvested from memory, disk, and the wire — Mimikatz and Responder lead.
- Reuse attacks (pass-the-hash / ticket) authenticate without the password.
- Guessing, interception, and discovery open the paths between hosts.
- Least privilege, allow lists, EDR, and MFA detect and contain movement.

Employability Skill: Trust

In security, you are trusted with deep access — trust is the currency of the job.

- **Performance vs. trust** (Simon Sinek) — a high performer you can't trust is a liability.
- **Practical and emotional** trust both matter: competence and character.
- Build it the small way: **show up**, **keep commitments**, and **admit when you're wrong**.



MID-STATE TECHNICAL COLLEGE · IT PROGRAMS

Questions?

Unit 12 · Ethical Hacking (10-151-160)

MID-STATE TECHNICAL COLLEGE